

Quanto custa um alerta?

Relatório da Avaliação Intermediária

DUPLA

Felipe Sarian e Pedro Henrique

CÓDIGO

025bc8

RANDOM_STATE

39569455

CLASSE DIFÍCIL

Bot

PARTE A O detector de intrusão

Dataset R2_025bc8 após a limpeza do Roteiro 2: 105.097 fluxos e 62 features. Split temporal com os primeiros 70% da ordem de captura de cada dia e Label no treino: 73.556 fluxos de treino (prevalência de ataque de 0,4019) e 31.541 de teste (0,4021). Random Forest com 100 árvores; modelo e teste salvos em saída/.

b) Da classe à probabilidade

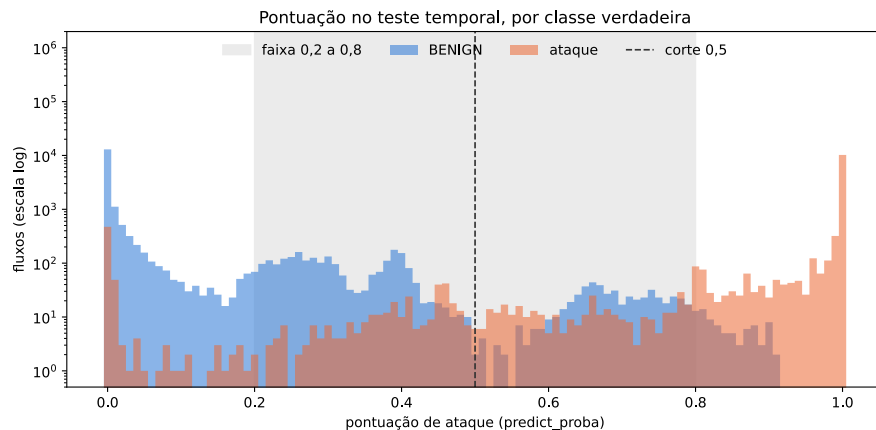


Figura 1. Histograma da pontuação de ataque no teste temporal, por classe verdadeira, em escala log. A faixa cinza vai de 0,2 a 0,8 e a linha tracejada marca o corte 0,5.

B.1

Os fluxos em que o modelo tem dúvida estão entre 0,2 e 0,8: são 3.548 fluxos, cerca de 11% do teste, sendo 2.825 benignos e 723 ataques. A maior parte do teste fica nos extremos, com 16.513 fluxos abaixo de 0,2 e 11.480 acima de 0,8. Mesmo em escala log, porém, a faixa do meio está longe de vazia. O tráfego benigno duvidoso forma um volume de algumas centenas de fluxos por valor de pontuação entre 0,2 e 0,45 e um segundo volume, de algumas dezenas, entre 0,55 e 0,8, enquanto os ataques se espalham por toda a faixa.

O corte 0,5 passa por uma região povoada. Ele cai num vale entre os dois volumes, mas ainda há 261 fluxos entre 0,45 e 0,55 (75 benignos e 186 ataques), de modo que qualquer deslocamento do limiar move dezenas de fluxos de um lado para o outro da matriz de confusão. O histograma também mostra 550 ataques com pontuação abaixo de 0,2, erros cometidos com convicção que nenhum ajuste fino em torno de 0,5 recupera.

c) ROC contra Precision-Recall

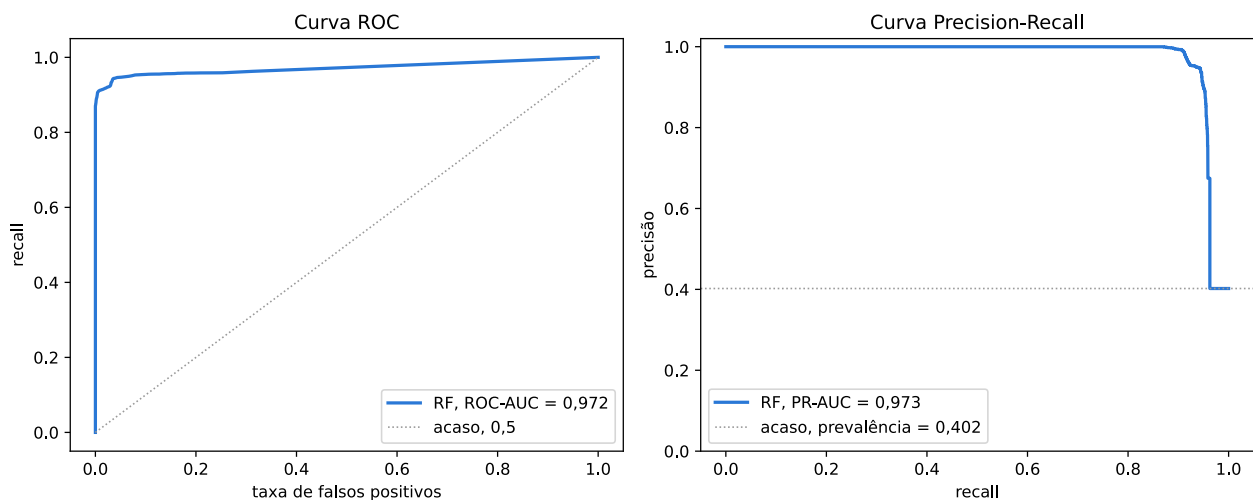


Figura 2. Curvas ROC e Precision-Recall do Random Forest no teste temporal, com a referência do acaso em cada uma.

C.1

Neste teste as duas áreas contam a mesma história: ROC-AUC de 0,972 e PR-AUC de 0,973. Isso acontece porque aqui o ataque não é uma classe rara, já que 40,2% do teste é ataque, e a curva ROC só esconde falsos positivos quando os negativos são muito mais numerosos que os positivos. As referências de acaso, no entanto, são diferentes: 0,5 para a ROC e 0,402 para a PR. As duas curvas mostram também o mesmo defeito: a precisão se mantém perto de 1 até um recall próximo de 0,9, e os últimos ataques só são alcançados quando a precisão desaba para o nível do acaso, porque esses ataques recebem pontuação 0.

Para a reunião com o gestor do SOC eu levaria a PR-AUC. A precisão tem o número de alertas no denominador e responde diretamente à pergunta do analista sobre quantos dos alertas da fila valem a pena. Além disso, em produção a proporção de ataques será muito menor que os 40% deste recorte, e nessa situação a ROC continuaria parecendo excelente enquanto a precisão caísse, que é a falácia da taxa-base.

C.2

Não é compatível. No corte 0,5 o recall global é 0,933, mas o recall do Bot é apenas 0,155: dos 592 fluxos de Bot no teste, a grande maioria passa sem alerta. O número global é dominado pelas classes volumosas e fáceis, e os 592 fluxos de Bot são menos de 5% dos 12.684 ataques do teste, pouco para mover a média.

Isso mostra que um único limiar para todas as classes esconde as classes difíceis. No caso do Bot, o limiar nem é a alavanca certa: 75,8% dos fluxos recebem pontuação 0, e mesmo com o corte em 0,05 o recall sobe só para 0,161, enquanto o volume de alertas falsos cresceria para todo o tráfego. O problema está na mudança de comportamento da campanha observada no Roteiro 2, não no ponto de corte. Por isso o desempenho precisa ser acompanhado por classe, e classes como o Bot pedem tratamento próprio, com features ou modelos específicos, em vez de um ajuste do limiar global.

d) Varredura de limiar

D.1

O F1 máximo está no limiar 0,80, com 0,9477 contra 0,9427 do corte 0,5. A curva do F1 não é monótona: há um máximo local em 0,45, com 0,9453, um vale em 0,60, com 0,9390, e o máximo global em 0,80.

Em relação ao corte 0,5, o limiar de 0,80 produz 510 falsos positivos a menos, 82 contra 592. Em troca, deixa passar 339 ataques a mais, 1.186 contra 847. O recall cai de 0,9332 para 0,9065, a precisão sobe de 0,9524 para 0,9929 e a fila do período encolhe de 12.429 para 11.580 alertas. O F1 trata essas duas trocas como equivalentes, o que o item e) vai reavaliar dando preços diferentes a cada erro.

e) O custo de um alerta

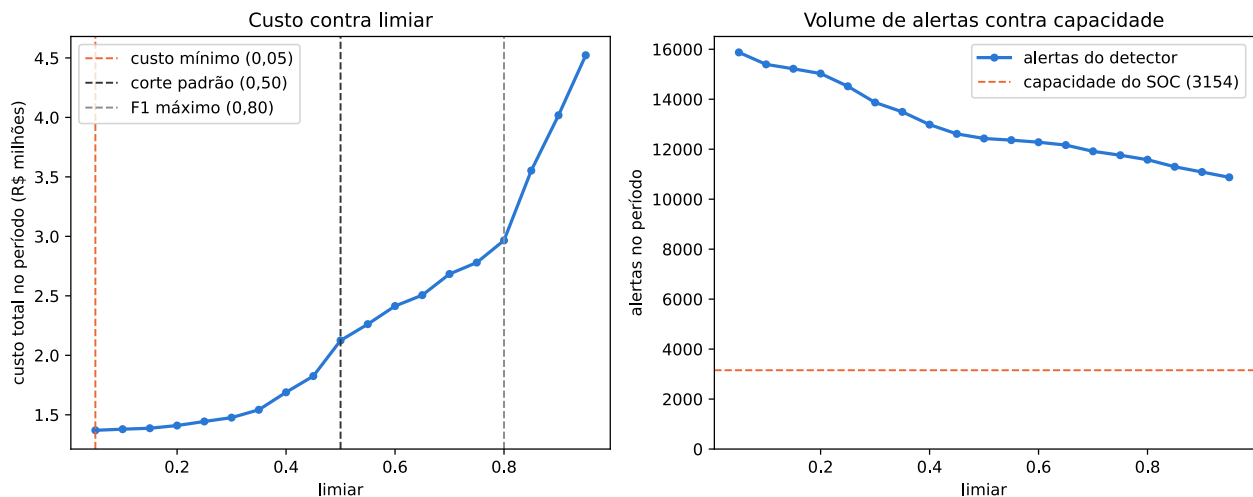


Figura 3. Custo total contra limiar, com C_{FP} = R\$ 12 e C_{FN} = R\$ 2.500, e volume de alertas contra a capacidade do SOC de 3.154 alertas no período.

E.1

O limiar de custo mínimo é 0,05, com R\$ 1.369.652 no período do teste. Ele economiza R\$ 754.952 em relação ao corte 0,5, que custa R\$ 2.124.604, e R\$ 1.596.332 em relação ao limiar de F1 máximo, que custa R\$ 2.965.984.

A explicação está na assimetria dos preços. Um falso negativo custa 208 vezes um falso positivo, então financeiramente vale a pena aceitar até 208 alarmes falsos para evitar um ataque que passa. O corte 0,5 deixa passar 847 ataques e o de F1 máximo deixa passar 1.186, contra 530 no limiar de 0,05. Os falsos positivos que esses cortes economizam, 3.129 e 3.639, não chegam perto de compensar.

O custo cresce de forma monótona com o limiar em toda a grade, ou seja, o mínimo está na borda inferior e não num vale. Uma varredura de 0,00 a 1,01 mostra que o ótimo verdadeiro é 0,00, alertar em todos os fluxos, com R\$ 226.284 e recall 1,0. O limiar de F1 máximo aponta na direção contrária porque o F1 trata os dois erros como equivalentes.

E.2

Não respeita. O limiar de custo mínimo gera 15.875 alertas, cinco vezes a capacidade de 3.154, que é 10% dos 31.541 fluxos do período de teste. Nenhum limiar da grade cabe: o menor volume é 10.875, no corte 0,95, onde a precisão já é 1,0.

Dentro da capacidade, o menor custo alcançável é R\$ 31.710.000, no corte 1,01, o único que cabe. Ele não alerta em nada e deixa passar os 12.684 ataques do teste. Nenhum corte que emita algum alerta cabe na fila: o menor volume não nulo possível é 10.230 alertas, no corte 1,00.

O limite não é do modelo. Um detector perfeito, com recall 1,0 e precisão 1,0, emitiria exatamente um alerta para cada um dos 12.684 ataques do teste, quatro vezes a capacidade do time. Nenhum limiar, modelo ou treino resolve isso, porque nesse ponto todos os alertas que sobram são verdadeiros e nenhum pode ser descartado. A restrição de 10% foi pensada para um ambiente em que o ataque é raro, e a prevalência deste recorte é 0,4021.

Por isso a decisão troca de lado. Ela sai do algoritmo e passa a ser de gestão: aumentar o SOC. Eu recomendaria o limiar de 0,05, que é o de custo mínimo, e levaria a capacidade ao gestor como o gargalo que precisa de investimento, não como um parâmetro a ser ajustado. Subir o corte para caber na fila não resolve, porque o excedente que hoje é alerta viraria ataque não detectado, ao custo de R\$ 2.500 cada. Enquanto o time não cresce, as saídas paliativas são automatizar a triagem e agrupar os alertas por campanha, já que 9.910 dos 15.875 alertas, 62,4% da fila, são varredura e negação de serviço, famílias em que muitos fluxos pertencem ao mesmo evento.

Se o custo do falso negativo for cinco vezes maior, R\$ 12.500, a recomendação não muda. O limiar de custo mínimo continua em 0,05, agora com R\$ 6.669.652, e a razão entre os custos passa de 208 para 1.041. A distância para os outros cortes aumenta: o corte 0,5 passa a custar R\$ 10.594.604 e o de F1 máximo R\$ 14.825.984. O argumento da capacidade fica mais forte ainda, porque cada alerta não triado passa a valer cinco vezes mais.

f) Validação: o número que você reportaria

F.1

A validação cruzada é a estimativa otimista: PR-AUC de 0,9980, com desvio de 0,0004 entre os folds, contra 0,9731 do split temporal. A diferença é de 0,0250.

O motivo é o embaralhamento. A validação cruzada estratificada sorteia as linhas sem olhar a ordem de captura, então cada fold treina com fluxos do começo e do fim da mesma campanha de ataque. O modelo aprende com informação do futuro e, na hora de prever, reencontra fluxos quase idênticos aos que já viu. O desvio de 0,0004 entre os cinco folds não mede esse otimismo. Ele só mostra que os folds são recortes aleatórios da mesma distribuição e por isso dão números parecidos. A evidência do otimismo é a distância para o split temporal.

O número que descreve o que o SOC vai ver na semana que vem é o do split temporal, 0,9731. Ele treina no passado e testa no futuro, que é a única coisa que a operação faz. A distância de 0,0250 entre as duas estimativas é uma medida do drift dentro do próprio dataset.

A classe difícil mostra o tamanho real do problema. No Roteiro 2, o recall do Bot caiu de 0,96 no split aleatório para 0,16 no temporal, e aqui o mesmo contraste se repete: nas previsões fora do fold da validação cruzada o recall do Bot é 0,9731, contra 0,1554 no split temporal. Nenhum fluxo de Bot recebe pontuação 0 na validação cruzada, enquanto no split temporal 75,8% recebem. Ou seja, a PR-AUC global cai 0,0250 enquanto o recall da classe difícil cai 0,8177. A média é dominada pelas classes volumosas e quase não registra o colapso. Levar a validação cruzada ao gestor esconderia justamente o caso que a operação mais precisa enxergar.

PARTE B

Fraude em cartão: Random Forest contra XGBoost

creditcard.csv.gz ordenado por Time, com as primeiras 70% das transações no treino: 199.364 transações de treino (384 fraudes) e 85.443 de teste (108 fraudes, prevalência de 0,00126). Random Forest com class_weight balanced_subsample e min_samples_leaf 2; XGBoost com scale_pos_weight de 518,18.

g) Dois modelos, duas áreas

G.1

Não. A ROC-AUC coloca o XGBoost na frente, 0,9756 contra 0,9462, e a PR-AUC coloca o Random Forest na frente, 0,8193 contra 0,7948. Nenhum dos números está errado, as duas áreas medem coisas diferentes.

Para escolher o modelo, a área certa é a PR-AUC. A taxa de falsos positivos da ROC tem no denominador as 85.335 transações legítimas do teste, e nele os 11 alarmes falsos do XGBoost no corte 0,5 são 0,013%, invisíveis. A precisão tem no denominador os alertas, e os mesmos 11 alarmes falsos são 12% dos 91 alertas do XGBoost. Com prevalência de

0,0013, a PR-AUC do acaso é 0,0013, enquanto a ROC-AUC do acaso continua em 0,5, o que deixa a ROC perto do teto para qualquer modelo razoável. Quando as duas áreas discordam numa classe rara, decide a PR, porque ela descreve o que o time de fraude vê na fila.

G.2

Não. No corte 0,5 o Random Forest erra quase só por omissão: 1 falso positivo e 33 fraudes perdidas, com precisão de 0,987 e recall de 0,694. O XGBoost emite 10 alarmes falsos a mais, 11 no total, e perde 5 fraudes a menos, 28, com precisão de 0,879 e recall de 0,741. Ele troca um pouco de fricção com o cliente por mais fraudes detectadas.

A diferença vem mais da escala das pontuações do que da qualidade dos modelos. As pontuações do XGBoost, treinado com `scale_pos_weight` de 518,18, ficam concentradas nos extremos: 78 das 108 fraudes passam de 0,95, contra nenhuma no Random Forest, e só 26 legítimas passam de 0,05, contra 84 no Random Forest. Por isso o 0,5 de um não é o 0,5 do outro, e comparar os dois no mesmo corte é comparar dois limiares diferentes. A comparação justa é pela varredura, que o item h) faz com o custo.

h) Custo com valor real: o falso negativo vale o que a fraude levou

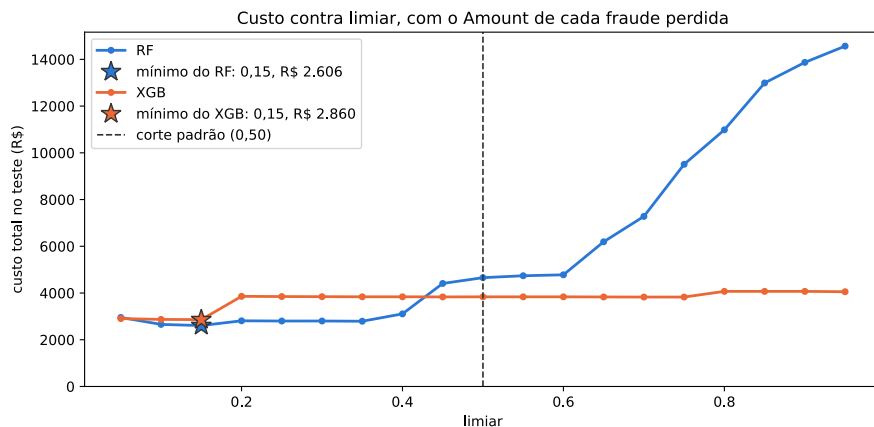


Figura 4. Custo total contra limiar para os dois modelos, com $C_{FP} = R\$ 5$ e C_{FN} igual ao Amount de cada fraude perdida. As estrelas marcam o mínimo de cada modelo.

H.1

A combinação de menor custo é o Random Forest no limiar 0,15, com R\$ 2.606,48 no período de teste. Em relação ao mesmo Random Forest no corte 0,5, que custa R\$ 4.656,73, a economia é de R\$ 2.050,25, 44% do custo do corte padrão. Nesse limiar o Random Forest emite 99 alertas, 85 verdadeiros e 14 falsos, e o recall sobe de 0,694 para 0,787.

O XGBoost também tem o mínimo em 0,15, com R\$ 2.860,20, e economiza R\$ 976,33 sobre o seu próprio corte 0,5. No corte 0,5, porém, o XGBoost seria o mais barato dos dois, R\$ 3.836,53 contra R\$ 4.656,73, de modo que comparar os modelos no 0,5 levaria à escolha errada. A curva do XGBoost é mais plana porque as suas pontuações ficam nos extremos e mover o limiar muda poucas decisões. A do Random Forest é mais sensível ao limiar e chega a um mínimo mais baixo.

H.2

Não coincidem. O F1 máximo do Random Forest está em 0,35, com F1 de 0,8497, quatro passos acima do limiar de custo mínimo, 0,15, onde o F1 é 0,8213. Em 0,35 passam 26 fraudes, somando R\$ 2.776,96; em 0,15 passam 23, somando R\$ 2.536,48.

A diferença está nas 3 fraudes com pontuação entre 0,15 e 0,35, de R\$ 1,00, R\$ 2,22 e R\$ 237,26. Descer o limiar de 0,35 para 0,15 custa 11 alarmes falsos a mais, R\$ 55 de fricção, e recupera R\$ 240,48. O F1 vê 3 fraudes contra 11 alarmes e prefere 0,35, porque conta erros sem olhar o preço. O custo vê R\$ 240,48 contra R\$ 55 e prefere 0,15, e quem paga a troca é praticamente uma única fraude, a de R\$ 237,26.

Os dois descrevem mostram por que o valor manda. As fraudes que passam são em geral pequenas: a mediana é de R\$ 7,32 no F1 máximo e de R\$ 7,59 no custo mínimo, e três quartos delas valem até R\$ 37,52 e R\$ 32,50. A perda, porém, é concentrada. A maior fraude perdida, de R\$ 1.096,99, passa nos dois limiares e responde sozinha por 43% do prejuízo no custo mínimo; ela passa até no corte 0,05, onde as fraudes perdidas ainda somam R\$ 2.533,95. Os degraus da curva de custo são fraudes caras como essa mudando de lado do limiar.

No XGBoost os dois limiares ficam ainda mais longe. O custo mínimo também está em 0,15, com R\$ 2.860,20, mas o F1 máximo está em 0,95, o último ponto da grade, onde o custo sobe para R\$ 4.055,15, R\$ 1.194,95 a mais. A causa é a mesma do Random Forest: o F1 conta erros sem olhar o preço. Como as pontuações do XGBoost ficam nos extremos, porém, a escolha do F1 cai no lado oposto da régua.

i) Limitações e viés: onde o modelo erra e o que o dataset esconde

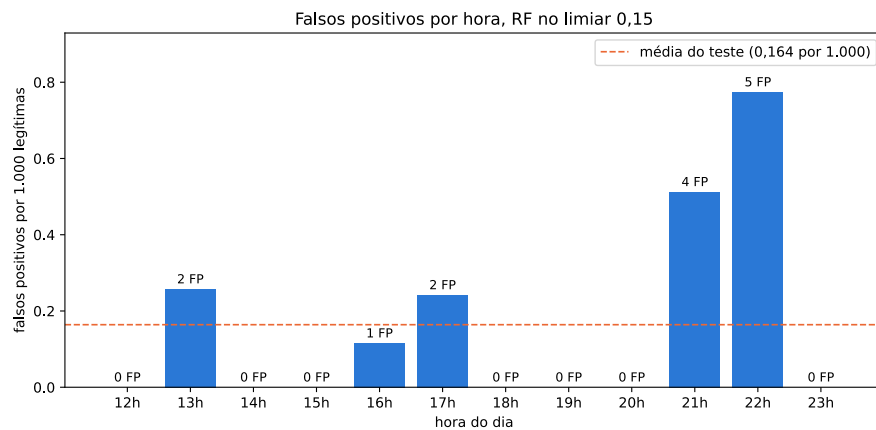


Figura 5. Falsos positivos por 1.000 transações legítimas, por hora do dia, para o Random Forest no limiar 0,15. O rótulo de cada barra traz a contagem absoluta.

1.1

Não. O recall fica entre 0,80 e 0,85 em três quartis de valor, mas cai para 0,455 nas compras de R\$ 5 a R\$ 20, onde só 5 das 11 fraudes são pegas. O prejuízo também é desigual: R\$ 2.384,86 dos R\$ 2.536,48 que passam, 94%, estão no quartil acima de R\$ 72,17, mesmo sendo o quartil de maior recall, 0,848.

Quem paga a conta dos falsos positivos é um grupo específico. Dez dos 14 alarmes falsos caem em compras de até R\$ 5, uma taxa de 0,46 por 1.000 legítimas contra 0,164 no teste inteiro, e os dois quartis do meio não têm nenhum. Para esse cliente, a fricção de R\$ 5 para confirmar a compra é igual ou maior que o valor da própria compra. Por hora, 9 dos 14 alarmes falsos caem às 21h e às 22h, com 0,51 e 0,77 por 1.000 legítimas, três a cinco vezes a média, enquanto sete das doze horas não têm nenhum. Essas duas horas também têm o pior recall, 0,50: à noite o modelo erra mais nos dois sentidos.

As contagens são pequenas, 14 alarmes falsos e 108 fraudes, então o padrão é um sinal a acompanhar, e não uma conclusão estatística. A hora é contada a partir da primeira transação do dataset, e o teste só cobre das 12h às 23h.

1.2

1. Origem e período. São cartões europeus de setembro de 2013, com 284.807 transações em dois dias, e o teste cobre só das 12h às 23h do segundo dia. Não há fim de semana, fim de mês nem sazonalidade, e não há nada do que move a fraude num banco brasileiro hoje, como Pix, compra parcelada e golpes de engenharia social. O próprio Amount está em euros e só foi tratado como real por convenção do enunciado.
2. Features transformadas. V1 a V28 são componentes de PCA, e as variáveis originais não foram divulgadas. Não dá para saber o que o modelo usa, nem explicar ao cliente por que a compra foi barrada, o que a LGPD exige quando ele pede revisão de uma decisão automatizada (art. 20). Também não dá para aplicar a mesma transformação aos dados de um banco brasileiro: o modelo não se transfere e teria de ser treinado do zero com outras features.
3. Rótulos. Class marca as fraudes que foram identificadas, em geral por contestação do titular, e a contestação chega com atraso. Fraude que ninguém contestou fica rotulada como legítima, e o modelo aprende a não vê-la. Parte das 85.335 legítimas do teste pode ser fraude: o recall de 0,787 pode estar superestimado, e alguns dos 14 alarmes falsos podem ser fraudes de verdade.

j) Parecer operacional

PARECER PARA O GESTOR DO TIME DE FRAUDE

Recomendo o Random Forest no limiar 0,15. Para escolher o modelo usei a PR-AUC, que mede a qualidade da fila de alertas, ou seja, em média, quantos dos alertas são fraude de verdade: 0,8193 contra 0,7948 do XGBoost. No período de teste, o Random Forest em 0,15 custa R\$ 2.606,48, contra R\$ 4.656,73 no corte padrão de 0,5, uma economia de 44%. Ele emite 99 alertas, 14 deles falsos, volume que o time absorve sem dificuldade, e pega 85 das 108 fraudes, com recall de 0,787 contra 0,694 no corte padrão.

A validação deve ser sempre temporal: treinar no passado e testar no período seguinte. A validação cruzada aleatória mistura passado e futuro e superestima o desempenho. Os números acima vêm de apenas dois dias de transações, com teste só entre 12h e 23h, e o custo de R\$ 5 por alarme falso é uma hipótese. Antes da implantação, o modelo precisa ser revalidado com meses de dados do próprio banco, com retreino periódico sempre testado na janela seguinte.

Depois da implantação, é preciso monitorar:

- o recall por faixa de valor, que é de apenas 0,455 nas compras de R\$ 5 a R\$ 20;
- o prejuízo das fraudes acima de R\$ 72,17, que concentram 94% da perda;
- os alarmes falsos por hora, já que 9 dos 14 caem às 21h e às 22h;
- o volume de alertas e a distribuição das pontuações, cuja mudança indica drift e a necessidade de recalculiar o limiar.